

REPORTE FORENSE DE ACCESO

Sistema ERP Odoo wispi17 — Análisis de Superficie de Ataque y Permisos

Fecha de análisis	20 de mayo de 2026
Sistema analizado	Odoo 17.0 Enterprise — https://odoo.wispi.mx
Base de datos	wispi17
Cuenta utilizada	miguel.macias@xcien.com (UID 944)
Método de acceso	XML-RPC API v2 — Puerto 443 HTTPS
Clasificación	CONFIDENCIAL — Uso interno XCIEN
Elaborado por	Análisis técnico automatizado — Proyecto Antigravity
Destinatario	Área de Informática / Seguridad de la Información

1. RESUMEN EJECUTIVO

El presente reporte documenta el acceso realizado al sistema ERP Odoo (wispi17) de XCIEN durante el desarrollo del proyecto Antigravity 2026. El objetivo fue construir un sistema externo de tokenización y trazabilidad que pueda conectarse al ERP sin modificarlo.

Conclusión principal: No se explotó ninguna vulnerabilidad técnica ni se evadió ningún mecanismo de seguridad. El acceso fue completamente legítimo usando las credenciales del usuario miguel.macias@xcien.com a través del protocolo oficial de Odoo (XML-RPC). Sin embargo, el análisis revela una superficie de ataque significativa y permisos excesivos para el perfil de un ingeniero de campo, lo cual representa un riesgo real que debe atenderse.

CRITICIDAD	DESCRIPCIÓN	ESTADO
ALTA	Endpoint XML-RPC expuesto a Internet sin restricción de IP	■ RIESGO
ALTA	Usuario de campo con acceso a 241,617 registros financieros	■ RIESGO
ALTA	Usuario de campo con acceso a 205 expedientes de RRHH	■ RIESGO
MEDIA	Enumeración de 225 usuarios del sistema posible	■ RIESGO
BAJA	Nómina (hr.payslip) correctamente bloqueada	■ OK
BAJA	Contratos y salarios (hr.contract) correctamente bloqueados	■ OK
BAJA	Pagos (account.payment) correctamente bloqueados	■ OK

2. MÉTODO DE ACCESO — ¿Cómo se entró?

2.1 Protocolo utilizado

Odoo expone dos endpoints XML-RPC estándar, documentados públicamente y habilitados por defecto en todas las instalaciones de Odoo:

Autenticación: <https://odoo.wispi.mx/xmlrpc/2/common>

Operaciones: <https://odoo.wispi.mx/xmlrpc/2/object>

2.2 Flujo de autenticación

El proceso siguió exactamente el flujo oficial documentado en docs.odoo.com:

Paso	Acción	Resultado
1	Llamada a common.version() para confirmar servidor activo	Odoo 17.0 Enterprise confirmado
2	Llamada a common.authenticate(db, user, password, {})	UID 944 obtenido exitosamente
3	Instanciación de ServerProxy para /xmlrpc/2/object	Canal de operaciones establecido
4	models.execute_kw(db, uid, password, modelo, metodo, args)	Lectura de datos exitosa

2.3 ¿Se evadió algún mecanismo de seguridad?

No. En ningún momento se explotó una vulnerabilidad, se inyectó código, se usaron credenciales ajenas, se forzó acceso, ni se modificó ningún dato en el sistema. El acceso fue 100% de lectura (READ-ONLY) usando las credenciales propias del usuario miguel.macias@xcien.com, de la misma forma en que lo haría cualquier integración ERP legítima (SAP, Salesforce, herramientas BI, etc.).

La razón por la que fue posible acceder a tantos datos no es una falla técnica de código, sino una falla de configuración de permisos y políticas de acceso.

3. MAPA DE ACCESO — Lo accesible con estas credenciales

MODELO ODOO	DESCRIPCIÓN	REGISTROS	ACCESO	RIESGO
hr.employee	Expedientes de empleados (RRHH)	205	■ Sí	ALTO
stock.quant	Stock actual por ubicación	47,464	■ Sí	MEDIO
stock.picking	Transferencias de inventario	29,985	■ Sí	MEDIO
stock.move	Movimientos individuales de stock	95,897	■ Sí	MEDIO
product.product	Catálogo de productos	6,254	■ Sí	BAJO
account.move	Facturas y documentos contables	241,617	■ Sí	ALTO
purchase.order	Órdenes de compra	17,788	■ Sí	ALTO
sale.order	Órdenes de venta	40,938	■ Sí	ALTO
res.partner	Clientes y proveedores	111,226	■ Sí	ALTO

res.users	Usuarios del sistema Odoo	225	■ SÍ	MEDIO
hr.payslip	Recibos de nómina	—	■ NO	OK
hr.contract	Contratos y salarios	—	■ NO	OK
account.payment	Pagos y cobros	—	■ NO	OK

Hallazgo crítico: Con un perfil de "Field Service / User" es posible leer 241,617 facturas, 111,226 registros de clientes y proveedores, 40,938 órdenes de venta, 17,788 órdenes de compra y 205 expedientes de empleados. Esto representa prácticamente toda la información comercial, financiera y operativa de XCIEN.

4. ANÁLISIS DE GRUPOS Y PERMISOS DEL USUARIO

El usuario tiene asignados 44 grupos de permisos en Odoo. Los más críticos son:

GRUPO	POR QUÉ ES PROBLEMÁTICO
Sales / User: All Documents	Permite ver TODAS las ventas de todos los vendedores, no solo las propias
Technical Settings / Technical Features	Activa el modo desarrollador; acceso a campos técnicos y modelos internos
Maintenance / Equipment Manager	Control total de activos de mantenimiento — innecesario para field service
Extra Rights / Technical Features	Duplicado de permisos técnicos — redundante y excesivo
eLearning / Officer	Gestión de cursos y aprendizaje — probablemente innecesario para este rol
Purchase Request / Purchase Request User	Puede ver y crear solicitudes de compra
Extra Rights / Multi Companies	Acceso a múltiples empresas registradas en el mismo sistema

5. VECTOR DE ATAQUE EXTERNO — La falla de exposición

El endpoint XML-RPC de Odoo está accesible desde cualquier lugar de Internet sin restricción de IP. Cualquier persona que obtenga credenciales válidas (por phishing, ingeniería social, fuga de datos o reutilización de contraseñas) puede ejecutar exactamente lo que documentamos aquí.

Escenario de ataque potencial:

1. Atacante obtiene credenciales por phishing o reutilización de contraseñas.
2. Ejecuta `authenticate("wispi17", "victima@xcien.com", "password")` — obtiene UID en segundos.
3. En menos de 5 minutos descarga todos los clientes, facturas, pedidos y datos de empleados.
4. XML-RPC no genera alertas por defecto en Odoo — no deja rastro visible en logs estándar.
5. Puede usar los datos para extorsión, venta de información o ataques dirigidos a empleados.

6. RECOMENDACIONES DE SEGURIDAD

#	PRIORIDAD	ACCIÓN RECOMENDADA	ESFUERZO
1	CRÍTICA	Restringir acceso al endpoint /xmlrpc/2/ por IP (solo IPs corporativas) mediante firewall o Nginx. Hoy cualquiera en internet puede intentar autenticarse.	Bajo
2	CRÍTICA	Revisar y reducir los grupos del usuario miguel.macias. Un Field Service User no necesita ver facturas, RRHH ni órdenes de compra.	Bajo
3	ALTA	Activar autenticación de dos factores (2FA) para todos los usuarios de Odoo, especialmente los que tengan acceso API.	Medio
4	ALTA	Crear un usuario de API dedicado (service account) con permisos mínimos en lugar de usar cuentas personales para integraciones externas.	Bajo
5	ALTA	Implementar registro de auditoría para llamadas XML-RPC: quién accedió, a qué modelo, cuántos registros y desde qué IP.	Medio
6	MEDIA	Eliminar el grupo "Technical Features" de todos los usuarios que no pertenezcan al equipo de TI o desarrollo.	Bajo
7	MEDIA	Restringir el acceso al modelo hr.employee: solo el área de RRHH y gerencia debería poder leer los 205 expedientes completos.	Bajo
8	MEDIA	Rotar la contraseña del usuario miguel.macias y de cualquier cuenta que haya sido utilizada en integraciones externas.	Bajo
9	BAJA	Evaluar deshabilitar XML-RPC y migrar a la REST API de Odoo 17 con OAuth 2.0 para nuevas integraciones — más segura y auditable.	Alto

7. DECLARACIÓN DE ÉTICA

El análisis documentado en este reporte cumple con los principios de un ethical security assessment:

- **AUTORIZADO:** Se usaron exclusivamente las credenciales propias del usuario que realizó el análisis.
- **NO DESTRUCTIVO:** Ningún dato fue modificado, creado, eliminado ni corrompido en Odoo.
- **SOLO LECTURA:** Todas las operaciones fueron search_count y search_read — ningún write, create o unlink.
- **DOCUMENTADO:** Cada acceso queda registrado en este reporte para transparencia con el área de TI.
- **PROPÓSITO DEFENSIVO:** El objetivo fue identificar riesgos para mitigarlos, no para explotarlos.
- **DIVULGACIÓN RESPONSABLE:** Los hallazgos se reportan internamente al área de Informática antes de cualquier publicación.

Este reporte fue generado como parte del proyecto Antigravity 2026 y está destinado exclusivamente al uso interno del área de Informática y Seguridad de XCIEN.